Sicurezza dei Sistemi Informativi

Appello d'Esame del 05 Settembre 2022

Anno Accademico 2021-2022

Politecnico di Torino — Docente: Prof. Cataldo Basile

2022-09-05

1 Testo Ufficiale dell'Esame

Domanda 1: Scenari di Attacco e Tecniche Avanzate

Dati le seguenti tecniche e scenari di attacco:

a. **Shadow Server**;

b. **Packet Sniffing**;

c. **Man-at-the-End (MATE)**;

d. **Advanced Persistent Threat (APT)**.

Per ciascuno, spiegare come funzionano, indicare gli obiettivi che un avversario intende conseguire e proporre efficaci contromisure e controlli di sicurezza per prevenirli o mitigarli.

Domanda 2: Regolamento GDPR

Spiegare cosa è il GDPR (General Data Protection Regulation), quale è il suo obiettivo istituzionale e illustrare nel dettaglio almeno 3 dei principi fondamentali che lo caratterizzano (ad esempio: minimizzazione, integrità e riservatezza, accountability).

Domanda 3: Algoritmo ChaCha20-256

Cosa è ChaCha20-256?

a. La versione completa di un algoritmo di crittografia simmetrica di tipo stream cipher con chiave a 256 bit e nonce.

b. Un algoritmo a blocchi basato sulla rete di Feistel.

c. Una funzione di hash a 256 bit.

d. Un algoritmo asimmetrico basato sul logaritmo discreto.

e. Nessuna delle precedenti.

Illustrare il funzionamento della funzione interna a 20 round (quarter round) basata sull'architettura ARX (Addition-Rotation-XOR) e spiegare perché è considerata resistente agli attacchi a canale laterale (side-channel attacks).

Domanda 4: Esercizio Architetturale DMZ e Ispezione Applicativa

Un'organizzazione deve proteggere i propri servizi web esposti al pubblico da minacce appartenenti alla OWASP Top 10 (es. SQL Injection, Cross-Site Scripting - XSS), permettendo al contempo l'amministrazione remota sicura da parte degli operatori di rete.

- Descrivere quale tipologia di firewall deve essere impiegata (Web Application Firewall - WAF vs Packet Filter tradizionale) e spiegare le differenze operative;
- Spiegare come il WAF gestisce il traffico cifrato HTTPS (terminazione TLS e modalità Reverse Proxy);
- Progettare la topologia di rete con DMZ evidenziando il posizionamento del WAF, del router perimetrale, dei web server e della console di gestione.

2 Soluzione Dettagliata e Guida Risolutiva

Soluzione Domanda 1: Scenari di Attacco e Mitigazioni

a. Shadow Server:

- *Funzionamento*: L'attaccante allestisce un'infrastruttura di server non autorizzata, clonata o nascosta (spesso all'interno della rete della vittima o nel cloud) che agisce come centro di comando e controllo (C2), server DNS ombra o repository segreto per esfiltrare dati.
- *Obiettivi*: Mantenimento della persistenza, bypass del monitoraggio di rete convenzionale ed esfiltrazione silente.
- *Contromisure*: Sistemi di Network Detection and Response (NDR), segmentazione di rete rigorosa, monitoraggio del traffico DNS (blocco di query verso domini di recente creazione), inventario centralizzato degli asset IT.

b. Packet Sniffing:

- *Funzionamento*: Intercettazione passiva di pacchetti di dati in transito su un segmento di rete condiviso impostando l'interfaccia di rete in modalità promiscua (es. mediante tool come Wireshark o tcpdump). Se la rete è commutata (switch), viene spesso combinato con tecniche attive come *ARP Spoofing/Poisoning* per convogliare il traffico verso la macchina dell'attaccante.
- *Obiettivi*: Acquisizione di credenziali in chiaro (es. password FTP, HTTP, Telnet), token di sessione, chiavi non protette e informazioni confidenziali.
- *Contromisure*: Cifratura end-to-end obbligatoria di tutto il traffico a livello applicativo (TLS/HTTPS, SSH) o di rete (IPsec), abilitazione di funzionalità di sicurezza sugli switch di accesso come *Dynamic ARP Inspection (DAI)*, *DHCP Snooping* e *Port Security*.

c. Man-at-the-End (MATE):

- *Funzionamento*: L'avversario ha il pieno possesso della macchina e del software target e agisce come operatore privilegiato per analizzare, decompilare e alterare l'applicazione.
- *Obiettivi*: Bypasso di controlli di licenza/DRM, estrazione di segreti industriali, cracking di algoritmi crittografici embedded.
- *Contromisure*: Tecniche di offuscamento multilivello, controlli di integrità a runtime (anti-tampering), anti-debugging, crittografia white-box e ancoraggio hardware tramite Trusted Platform Module (TPM) e Secure Boot.

d. Advanced Persistent Threat (APT):

- *Funzionamento*: Campagna di cyber-attacco prolungata, mirata e sponsorizzata da attori statali o gruppi criminali avanzati. Segue le fasi del *Cyber Kill Chain* (Reconnaissance, Weaponization, Delivery via spear-phishing, Exploitation, Installation, Command & Control, Lateral Movement e Actions on Objectives).
- *Obiettivi*: Spionaggio industriale, furto di segreti militari/governativi, sabotaggio di infrastrutture critiche.

- *Contromisure*: Architettura Zero Trust, Endpoint Detection and Response (EDR) con analisi comportamentale euristica, Security Operations Center (SOC) attivo 24/7 con threat hunting proattivo, patch management rigoroso e segmentazione avanzata (micro-segmentazione).

Soluzione Domanda 2: Obiettivi e Principi Cardine del GDPR

Obiettivo del GDPR (Regolamento UE 2016/679): Armonizzare le normative sulla protezione dei dati personali all'interno dell'Unione Europea, tutelando il diritto fondamentale delle persone fisiche alla riservatezza e al controllo sui propri dati personali, garantendo al contempo la libera circolazione dei dati all'interno del mercato unico digitale.

Analisi Dettagliata di 3 Principi Cardine:

1. **Minimizzazione dei dati (Art. 5.1.c)**: I dati personali devono essere limitati a quanto strettamente necessario rispetto alle finalità per cui sono trattati. L'organizzazione non può raccogliere dati "a scopo preventivo" o non strettamente correlati al servizio erogato.

2. **Integrità e Riservatezza (Art. 5.1.f)**: Il trattamento deve garantire un'adeguata sicurezza dei dati personali, compresa la protezione, mediante misure tecniche (cifratura, pseudonimizzazione, controllo accessi) e organizzative (procedure aziendali, audit) adeguate, da trattamenti non autorizzati o illeciti e dalla perdita, distruzione o danno accidentale.

3. **Responsabilizzazione / Accountability (Art. 5.2)**: Il titolare del trattamento non solo è responsabile del rispetto dei principi, ma deve essere attivamente in grado di comprovare tale rispetto attraverso documentazione formale (Registro dei trattamenti, Valutazione di Impatto sulla Protezione dei Dati - DPIA, policy di sicurezza verificate).

Soluzione Domanda 3: ChaCha20-256 e Architettura ARX

Analisi Puntuale delle Opzioni:

- **a. VERA**: ChaCha20 è la versione standard a 20 round di un cifrario simmetrico a flusso (*stream cipher*) ad elevate prestazioni ideato da Daniel J. Bernstein. Utilizza una chiave segreta a 256 bit (32 byte), un contatore a 32 bit e un nonce a 96 bit (nella specifica standard IETF RFC 7539 / RFC 8439), producendo un keystream sincrono applicato in XOR al plaintext.

- **b. FALSA**: ChaCha20 non è un cifrario a blocchi e non si basa affatto sulla rete di Feistel (come invece DES o Blowfish). La sua struttura interna è basata su trasformazioni ARX a round su una matrice di parole.

- **c. FALSA**: Non è una funzione di hash crittografica (anche se la funzione di compressione di BLAKE/BLAKE2/BLAKE3 è strettamente derivata dal core di permutazione di ChaCha).

- **d. FALSA**: Non è un algoritmo asimmetrico a chiave pubblica e non ha legami con il problema del logaritmo discreto (come Diffie-Hellman o ElGamal); è strettamente crittografia simmetrica a chiave segreta condivisa.

- **e. FALSA**: Poiché l'affermazione (a) è esatta ed esaustiva, l'opzione (e) è falsa.

Funzionamento Interno e Operazione Quarter Round (ARX): Lo stato interno di ChaCha20 è una matrice 4×4 di parole a 32 bit (totale 512 bit = 64 byte):

- 4 parole di costanti fisse (`"expand 32-byte k"`);
- 8 parole di chiave crittografica (256 bit);
- 1 parola di contatore di blocco (32 bit);
- 3 parole di nonce (96 bit).

L'operazione fondamentale è il **Quarter Round (QR)**, che opera su 4 parole (a, b, c, d) impiegando solo tre operazioni elementari estremamente veloci: Addizione modulo 2^{32} ($+$), Rotazione circolare di bit a sinistra ($\lll$) e bitwise XOR ($\oplus$):

$$\begin{aligned} a &\leftarrow a + b; \quad & d &\leftarrow (d \oplus a) \lll 16; \\ c &\leftarrow c + d; \quad & b &\leftarrow (b \oplus c) \lll 12; \\ a &\leftarrow a + b; \quad & d &\leftarrow (d \oplus a) \lll 8; \\ c &\leftarrow c + d; \quad & b &\leftarrow (b \oplus c) \lll 7; \end{aligned}$$

Un round completo applica 4 QR alle colonne seguito da 4 QR alle diagonali. ChaCha20 ripete questo ciclo per 10 volte (totale 20 round). Al termine, lo stato finale viene sommato allo stato iniziale per generare un blocco di keystream da 64 byte.
Resistenza agli Attacchi a Canale Laterale (Side-Channel): A differenza di AES, che nelle implementazioni software tradizionali richiede lookup table (*S-Box*) dipendenti dalla chiave (soggette ad attacchi di tipo cache timing attack causati da cache miss/hit), ChaCha20 utilizza esclusivamente istruzioni ARX a tempo costante (*constant-time*). Poiché l'esecuzione non effettua accessi in memoria dipendenti dai dati segreti né salti condizionali, ChaCha20 è nativamente immune a tali attacchi temporali.

Soluzione Domanda 4: WAF e Progettazione Architetturale DMZ

WAF vs Packet Filter Tradizionale:

- **Packet Filter (L3/L4)**: Ispeziona solo indirizzi IP sorgente/destinazione, protocollo di trasporto e porte (TCP/UDP). Non ha alcuna visibilità all'interno del payload dei dati applicativi e non può rilevare attacchi complessi nascosti all'interno di richieste HTTP lecite (es. `GET /search?q=' OR 1=1--`).
- **Web Application Firewall (WAF - L7)**: Lavora a livello applicativo. Esegue il parsing completo del protocollo HTTP/HTTPS, decodifica parametri URL, header, cookie e payload POST (JSON, XML). Applica motori a regole (es. OWASP Core Rule Set) e modelli euristici/comportamentali per bloccare SQLi, XSS, Command Injection, CSRF e attacchi al controllo accessi.

Gestione del Traffico Cifrato HTTPS (SSL/TLS Offloading): Poiché il traffico web viaggia ormai quasi universalmente su canali cifrati HTTPS, un WAF non può ispezionare il contenuto se il traffico è cifrato end-to-end con le chiavi del server. Il WAF viene quindi configurato in modalità **Reverse Proxy**:

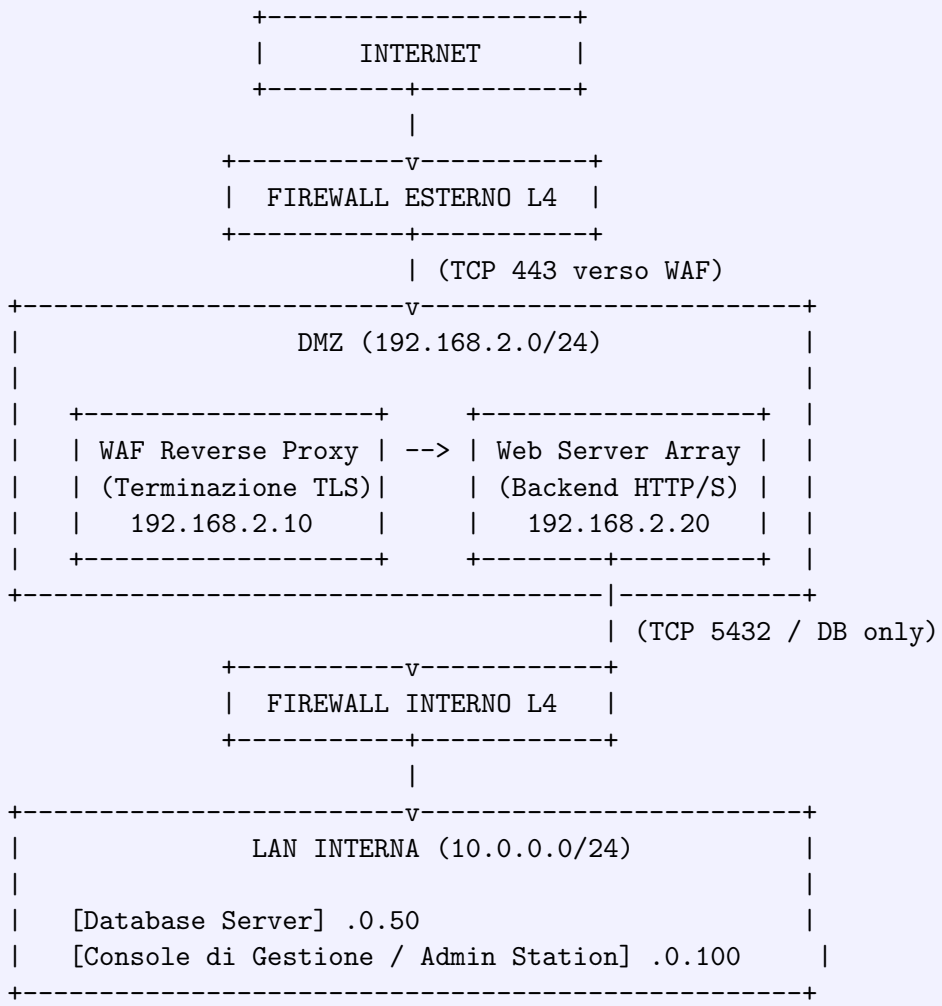
1. Il certificato digitale X.509 e la relativa chiave privata del sito web vengono installati a bordo del WAF.

2. Il client esterno stabilisce la connessione TLS direttamente con il WAF (che termina la sessione TLS).

3. Il WAF decifra la richiesta HTTP, esegue l'ispezione approfondita del payload e verifica le policy di sicurezza.

4. Se la richiesta è lecita, il WAF inoltra la richiesta al Web Server backend nella DMZ (tramite una seconda connessione cifrata interna o su rete isolata dedicata).

Topologia di Rete (Architettura DMZ Two-Tier con WAF Reverse Proxy):



Instradamento, Subnetting e Regole Chiave:

- **Firewall Esterno**: Permette dall'esterno solo il traffico TCP 443 verso l'IP pubblico/DMZ del WAF (`192.168.2.10`). Blocca ogni accesso diretto ai web server e alla LAN interna.
- **WAF nella DMZ**: Termina la sessione HTTPS, ispeziona il payload HTTP per minacce OWASP, e se lecito effettua reverse proxying verso i Web Server (`192.168.2.20`).
- **Firewall Interno**: Autorizza unicamente le query TCP (es. porta 5432 per PostgreSQL) provenienti dai soli Web Server DMZ verso il Database interno (`10.0.0.50`). Nessun host DMZ può iniziare connessioni verso la Console di Gestione.

- **Console di Gestione** (`10.0.0.100`): Amministra WAF e Web Server attraverso connessioni cifrate SSH/HTTPS in uscita dalla LAN interna verso la DMZ con autenticazione a più fattori (MFA).

Alternative Implementation Note: Strutture Rust per un Web Application Firewall

Nella progettazione di un WAF ad alte prestazioni in Rust (es. implementato come middleware per Hyper o Tower):

- `std::sync::Arc<RegexSet>`: Le migliaia di firme e pattern per l'individuazione di SQLi/XSS sono compilate in una struttura `RegexSet` immutabile e condivisa a zero-copy tra tutti i thread asincroni di gestione delle richieste web.
- `tokio::sync::mpsc`: Canale asincrono a elevate prestazioni con backpressure per trasferire i payload bloccati e gli eventi di sicurezza a un worker thread deputato alla notifica SIEM/SOC senza bloccare il thread di I/O del server.